

Чек-лист must have API проверок

Помимо положительных сценариев с учётом различных классов эквивалентности, граничных значений, диаграмм перехода состояний и т. д. важно также проверять случаи, связанные с обеспечением ИБ и корректным ответом системы для различных состояний.

Ниже представлен список-напоминание, какие проверки обязательно стоит проверить, но он не окончателен.

Критические сценарии

1. 401 — запрещён доступ для неавторизованных пользователей (требование всей системы). В SC можно авторизоваться 3 способами: BasicAuth, SC token (можно передавать в том числе через query-параметр), JWT (используется при общении с IAM Proxy, пользователи через него не работают). Стоит базово проверить, что аутентификация происходит до проверки сущностей, которые используются в запросе, например, на существование.

1. Заголовок Authorization отсутствует.

2. Заголовок Authorization имеет пустое значение: `Authotization:`

3. Заголовок Authorization имеет невалидный token: `Authotization: token <40 случайных число-буквенных символов>`

4. Заголовок Authorization имеет пустой token: `Authotization: token`

5. Заголовок Authorization имеет отозванный token: `Authotization: token <ранее выданный токен, но удаленный>`

6. Заголовок Authorization имеет несуществующий BasicAuth: `Authotization: Basic btoa(fakeuser:fakepass)`

7. Заголовок Authorization имеет содержит невалидный пароль BasicAuth: `Authotization: Basic btoa(realuser:fakepass)`

2. 403 — отсутствует доступ к сущностям по ролевой модели или другой бизнес-логике.

1. Если требуется привилегия read, то

1. Для проекта:

1. Доступ к ограниченному должен быть без выдачи привилегий пользователю.

2. Приватный не должен быть доступен без выдачи прав.

3. Приватный доступен при выдаче прав.

2. Для репозитория:

1. Публичный репо доступен без выдачи прав на проект и на репо.

2. Ограниченный проект и приватный репо без выдачи прав — действие в репо недоступно.

2. Для всех привилегий — проверяем случаи с учетом наследования прав в ролевой моедли.

3. Если в СТ указано требование по наличию скоупа для токена (если нет, то все равно уточняем, так как могли забыть), то

1. Если в запросе указан токен без скоупа — 403.
2. Если токен со скоупом — запрос успешно выполняется.

Важные сценарии

Обращаем внимание, какие допустимые и недопустимые значения могут принимать поля в теле, query-, path-параметрах.

Если это текст, то проверяем латиницу, кириллицу, спецсимволы, пробельные символы, эмодзи; длину текста (учтите, что кириллица содержит больше байтов на 1 символ, поэтому может превысить раньше максимальную длину (так как по ошибке могут считать байты, а не символы в строке)).

Дополнительно

1. Обращаем внимание на наличие требований аудита к операциям: обычно применяется для действий по изменению состояния сущности (создание, изменение, удаление); получение чаще всего не добавляется в аудит.
2. Проверка отображения в swagger: корректно отображаются параметры, тело и его схема, ответ и его схема, статус-коды. При отправке запроса формируется корректный URL.